

TLS Security Training

Juraj Somorovsky



Overview of the Training

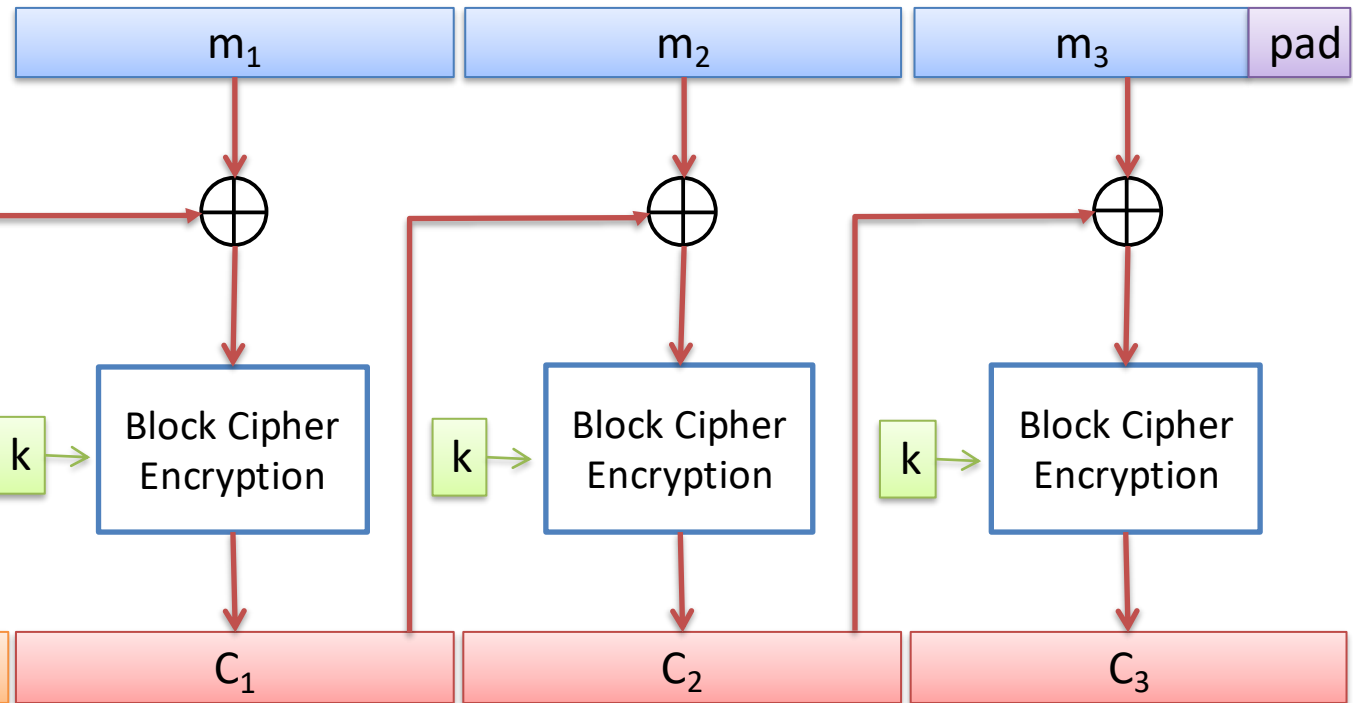
1. **Crypto Basics**
2. **Transport Layer Security**
3. **Certificates and PKI**
4. **Attacks on TLS**
5. **TLS 1.3**
6. **TLS Evaluation Tools**
7. **TLS Implementations**

Examples of Popular Hash Functions

Name	Output length	Comment
MD5	128 b	• Cryptographically broken (*) (easy to find collisions) • Not suitable for future use
SHA-1	160 b	• Broken since March 2017 • Shattered attack
SHA-256	256 b	No non-trivial attacks
SHA-3	224 b, 256 b, 384 b, 512 b	• Winner of SHA-3 competition • Good choice for new applications

Encryption Example: AES-CBC

Plaintext m



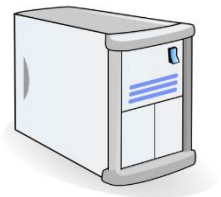
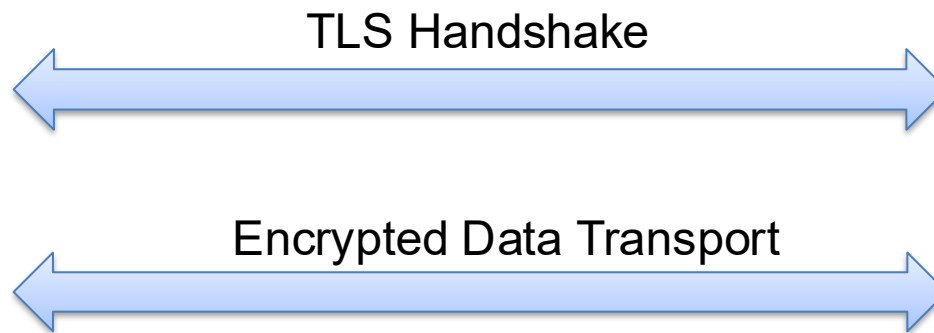
Ciphertext C

TLS Protocol Flow (High Level)

1. TLS Handshake

- Selection of algorithm, version, extensions
- Key exchange

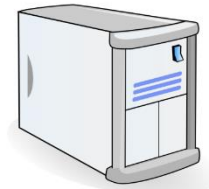
2. Encrypted and authenticated data transport



TLS 1.2 Handshake



RSA priv, pub
Certificate (pub)



Cipher suites
TLS version
Random

ClientHello

ServerHello

Cipher suite selection
Random

Certificate

RSA pub

ServerKeyExchange

DH-key
RSA-Sign(priv, DH-key)

ServerHelloDone

DH-key

ClientKeyExchange

Let's Encrypt!!!

ChangeCipherSpec

(Client-) Finished

HMAC over
previous
messages with
the derived key

ChangeCipherSpec

Let's Encrypt!!!

(Server-) Finished

pms

Certificate

Document that ...

- Belongs to an identity
- Has Expiration Date
- Contains issuer info
- Contains a public key

X.509 Format

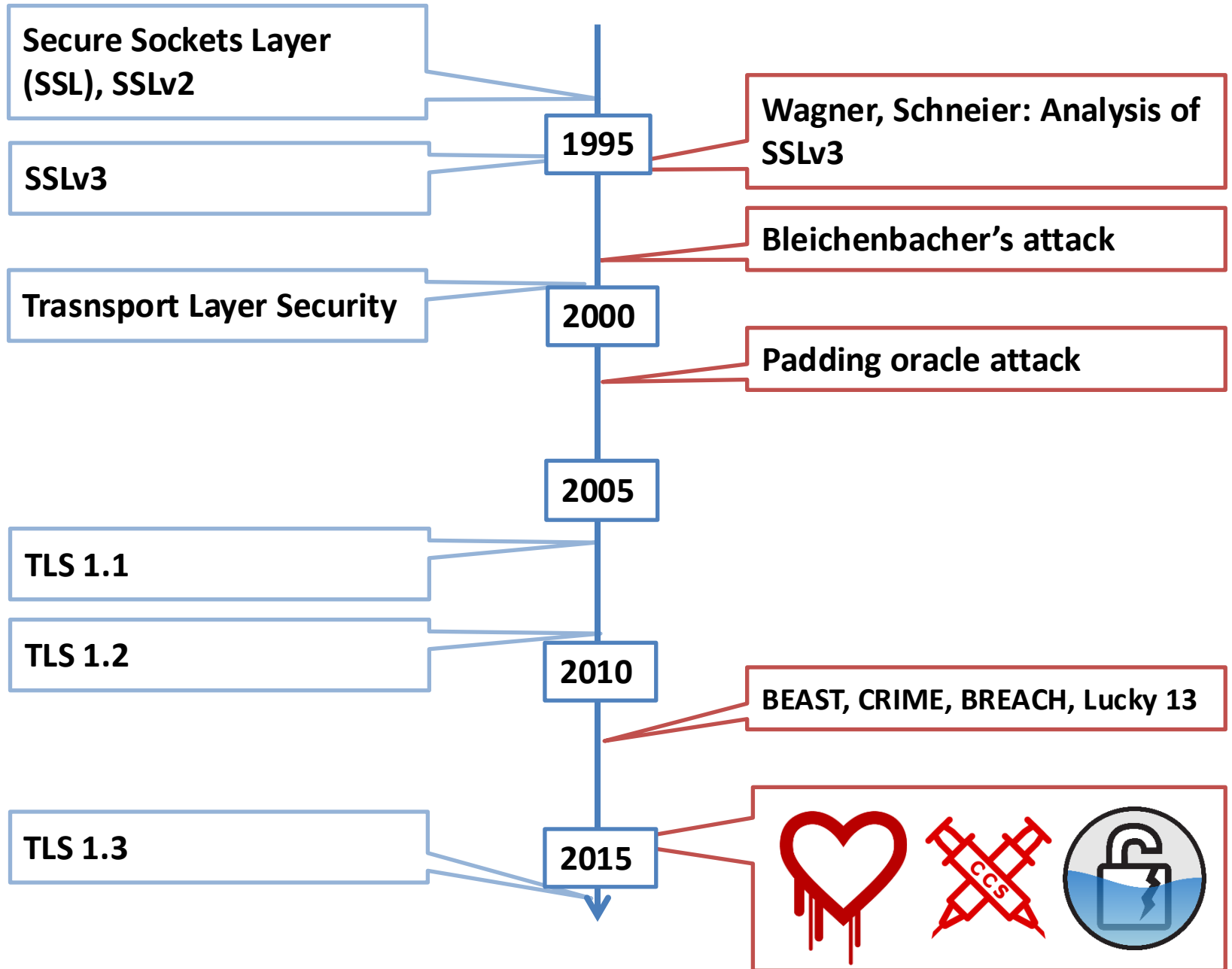
Certificate

*.wikipedia.org		E7	ISRG Root X1
Subject Name			
Common Name	*.wikipedia.org		
Issuer Name			
Country	US		
Organization	Let's Encrypt		
Common Name	E7		
Validity			
Not Before	Thu, 09 Oct 2025 23:02:03 GMT		
Not After	Wed, 07 Jan 2026 23:02:02 GMT		
Subject Alt Names			
DNS Name	*.m.mediawiki.org		
DNS Name	*.m.wikibooks.org		
DNS Name	*.m.wikidata.org		
DNS Name	*.m.wikimedia.org		
DNS Name	*.m.wikinews.org		
DNS Name	*.m.wikipedia.org		
DNS Name	*.m.wikiquote.org		
DNS Name	*.m.wikisource.org		
DNS Name	*.m.wikiversity.org		
DNS Name	*.m.wikivoyage.org		
DNS Name	*.m.wiktory.org		
DNS Name	*.mediawiki.org		
DNS Name	*.planet.wikimedia.org		
DNS Name	*.wikibooks.org		
DNS Name	*.wikidata.org		
DNS Name	*.wikifunctions.org		
DNS Name	*.wikimedia.org		
DNS Name	*.wikimediafoundation.org		
DNS Name	*.wikinews.org		
DNS Name	*.wikipedia.org		
DNS Name	*.wikiquote.org		
DNS Name	*.wikisource.org		
DNS Name	*.wikiversity.org		
DNS Name	*.wikivoyage.org		

DigiNotar

- Summer 2011: completely compromised
 - 128 certificates issued
- All root certificates **revoked**
 - DigiNotar went out of business
- Breach used for real Man-in-the-Middle attacks
- Targeted mostly Gmail accounts, 95% in Iran

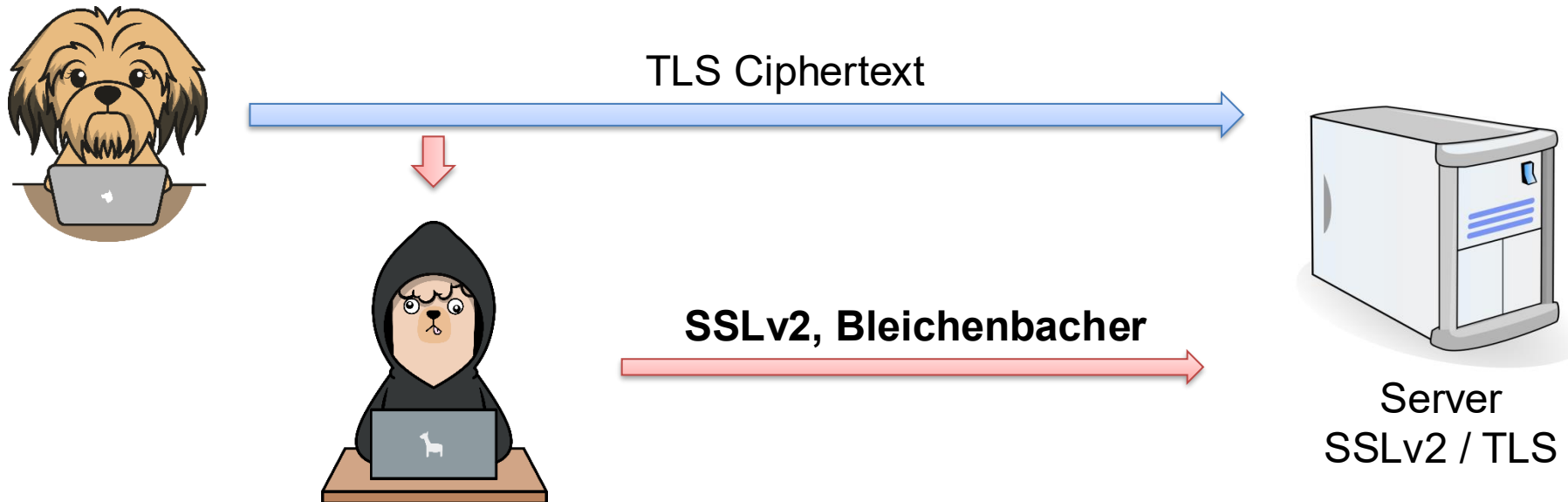
TLS History



DROWN: Breaking TLS using SSLv2



- Problem: many servers still supporting SSLv2
- SSLv2 vulnerable to Bleichenbacher's attack



Legacy protocols can compromise the security of modern protocols and deployments.

TLS 1.3: Design Motivation

- Improving performance
- Preventing known attacks by removing/specifying proper crypto algorithms:

- Bleichenbacher's attack



No TLS-RSA

- Padding oracles



No CBC ciphers

- Weak key/block lengths



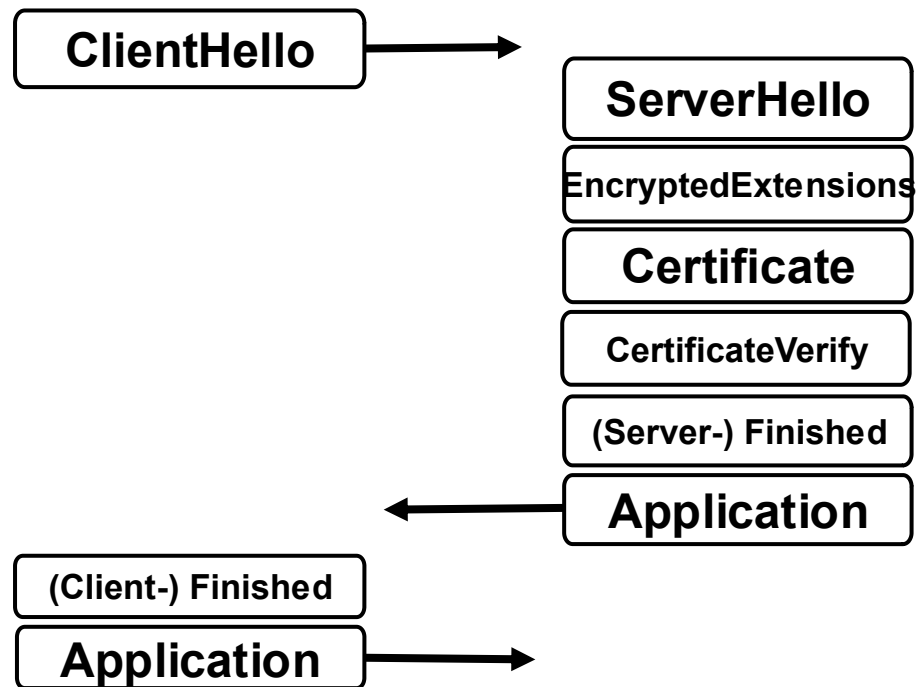
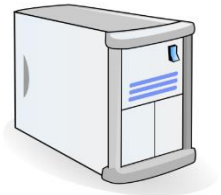
No 3DES, ...

- Weak custom parameters



Only standardized
(EC)DH groups

TLS 1.3 Handshake



TLS-Attacker and TLS-Scanner

- TLS-Attacker:
 - Java-based framework for analyzing TLS libraries, building proof of concept attacks, fuzzing
 - Rather for TLS developers
 - Link: <https://github.com/TLS-Attacker/TLS-Attacker>
- TLS-Scanner
 - Based on TLS-Attacker
 - Allows you to scan and evaluate your infrastructure
 - Validates your deployment against TLS recommendations issued by BSI or NIST
 - Link: <https://github.com/TLS-Attacker/TLS-Scanner>

Potential TLS Handshake Failures

- Is there a valid protocol version selection?
- Is there a valid cipher suite selection?
- Not all cipher suites are supported for all TLS versions!
- Did your client send the *server name indication* extension?
- Did your client send the *renegotiation info* extensions?